

Project Report: Resilient Command and Control (C2) Infrastructure

Tailored for Advanced Persistent Threat (APT) Emulation

Red Team Operations - Taha Marouani 2ATEL2

Academic Year 2025–2026

Contents

1 Executive Summary and Project Rationale 3

1.1 Why This Project is Necessary 3

1.2 Key Achievements and Professional Rigor 3

2 Fundamentals: The C2 Concept Explained 3

2.1 What is Command and Control (C2)? 3

2.2 Core Design Principle: Layered Defense (The Onion Model) 3

3 Architecture Deep Dive: Component Breakdown 3

3.1 Layer A: Automation and Management (IaC) 4

3.2 Layer C: C2 Redirectors and Evasion Filter 4

3.3 Layer D: Primary C2 Core (The Crown Jewel) 4

3.4 Layer E: Decoy Listener and Canary Trap 4

4 Advanced Threat Emulation Capabilities 5

4.1 MFA Bypass Phishing 5

4.2 High-Fidelity Domain Spoofing 5

4.3 Proactive Security Verification 5

5 Conclusion and Key Project Takeaways 5

5.1 Project Takeaways 5

1 Executive Summary and Project Rationale

This document details the architecture and implementation of a professional-grade Command and Control (**C2**) infrastructure. This system is the backbone for simulating highly sophisticated cyber attacks (**Adversary Emulation**) to stress-test our organization's cyber defenses.

1.1 Why This Project is Necessary

Traditional security testing often uses simple, easily detectable attack servers. Modern cyber-criminals and nation-state actors (**APTs**) use resilient infrastructure that can evade detection and survive defensive action. This project ensures our Red Team testing is **realistic** and , forcing our security monitoring and incident response teams (Blue Team) to defend against **world – class threats**.

1.2 Key Achievements and Professional Rigor

- ✓ **Automated Resilience:** The ability to destroy and rebuild parts of the attack infrastructure in minutes, countering detection attempts.
- ✓ **Zero-Trust Security:** The core command server is completely isolated and inaccessible from the public internet.
- ✓ **Advanced Evasion:** Implementation of traffic filtering that detects and redirects security scanners, protecting the core asset.

2 Fundamentals: The C2 Concept Explained

2.1 What is Command and Control (C2)?

In a cyber operation, the C2 system is the communication link between the attacker and the compromised computer (the target).

- **Analogy (Submarine):** If the malicious implant is a submarine operating deep within the target network, the C2 server is the **base station** that issues orders and receives intercepted intelligence.
- **The Infrastructure:** The C2 Infrastructure is the entire network of servers, proxies, and domains designed to make this communication link look like normal web traffic (e.g., **browsing YouTube** rather than malicious activity).

2.2 Core Design Principle: Layered Defense (The Onion Model)

Our C2 architecture is built with a minimum of **three layers of separation** between the public internet and the sensitive Core server, maximizing security through redundancy and isolation.

3 Architecture Deep Dive: Component Breakdown

The project is structured into five distinct layers, each serving a critical security or operational function.

3.1 Layer A: Automation and Management (IaC)

- ▶ **Concept: Infrastructure as Code (IaC):** This means the entire infrastructure is defined in human-readable code (**Terraform** and **Ansible**), not manually built via a web interface.
- ▶ **Tooling: Terraform** (for cloud resource deployment) and **Ansible** (for operating system configuration).
- ▶ **Security Impact: Enables Automated Disposability.** If an attack component is detected, the system can execute a controlled **Burn and Rebuild** cycle in under 10 minutes, changing the IP, hostname, and server configuration to maintain operational continuity.

3.2 Layer C: C2 Redirectors and Evasion Filter

- ▶ **Role:** These are the public-facing proxy servers. They absorb all incoming traffic and implement the primary defense mechanism.
- ▶ **Tooling: Nginx** configured as a Reverse Proxy.
- ▶ **Critical Function: Header-Based Filtering:** The Nginx server is programmed to only forward traffic to the C2 Core (Layer D) if the request contains a secret, non-standard **HTTP Header**. All other traffic (scanners, analysts) is deflected.
- ▶ **Advanced Stealth: CDN Fronting:** Traffic is routed through a major Content Delivery Network (e.g., **AWS CloudFront**) to obscure the Redirector's true IP address, making the attack blend with major web traffic.

3.3 Layer D: Primary C2 Core (The Crown Jewel)

- ▶ **Role:** Hosts the actual C2 software (e.g., Cobalt Strike) and manages all active implant sessions.
- ▶ **Core Security: Zero Trust Principle:** The server's firewall is configured to **block 100% of the public internet**.
- ▶ **Access Control:** The only permissible traffic is strictly defined: only the specific IP addresses of the active Redirectors (Layer C) are allowed to connect to the C2 port. This ensures the Core is **impossible to fingerprint** from the public internet.

3.4 Layer E: Decoy Listener and Canary Trap

- ▶ **Role:** An isolated server acting as a **Canary Trap** to catch unauthorized traffic deflected from the Redirectors.
- ▶ **Detection Logic:** If a Blue Team analyst or security scanner attempts to connect to the Redirector without the secret header, they are redirected here. This server is configured to look benign (e.g., **a standard error page**).
- ▶ **OPSEC Alerting:** Any connection to this decoy triggers an **immediate, high – priority alert** (via Slack webhook or similar). This instant notification allows the Red Team to proactively terminate the exposed infrastructure before detection is finalized.

4 Advanced Threat Emulation Capabilities

This project integrates tools that simulate the most advanced TTPs currently used by threat groups.

4.1 MFA Bypass Phishing

◇ **Tool:** Evilginx.

◇ **Function:** This tool hosts a dynamic, real-time mirror of a target's login page. It captures not only the username and password but also the crucial **session cookie** (the digital token proving successful login), effectively **bypassing Multi – Factor Authentication (MFA)**.

4.2 High-Fidelity Domain Spoofing

◇ **Tools:** DNStwist and URLCrazy.

◇ **Function:** These tools generate and verify thousands of subtle domain name variations (e.g., replacing 'l' with '1') and **Punycode** (Unicode) domains that are visually indistinguishable from legitimate websites. This is used to craft the most convincing and difficult-to-spot phishing attacks.

4.3 Proactive Security Verification

◇ **System:** Automated Health Checks.

◇ **Function:** Scripts continuously check the deployed domains and IPs against public threat intelligence feeds (e.g., **Google Safe Browsing API**) to ensure they have not been black-listed. If a flag is detected, the check automatically triggers the IaC system to retire the compromised asset.

5 Conclusion and Key Project Takeaways

This project successfully establishes a mature, professional-grade C2 infrastructure that sets a new standard for our internal adversary emulation exercises.

5.1 Project Takeaways

1. **Risk Reduction:** By accurately simulating **real – world APT TTPs** using this resilient infrastructure, we force our defensive teams to elevate their capabilities against the threats that matter most.
2. **Compliance and Auditability:** The use of **IaC** (Terraform) ensures that the entire attack infrastructure is fully documented, auditable, and traceable, satisfying all compliance requirements for penetration testing.
3. **Operational Efficiency:** The automated **Burn and Rebuild** cycle significantly reduces the time required to manage infrastructure, allowing the Red Team to focus more on execution and intelligence gathering, rather than administration.